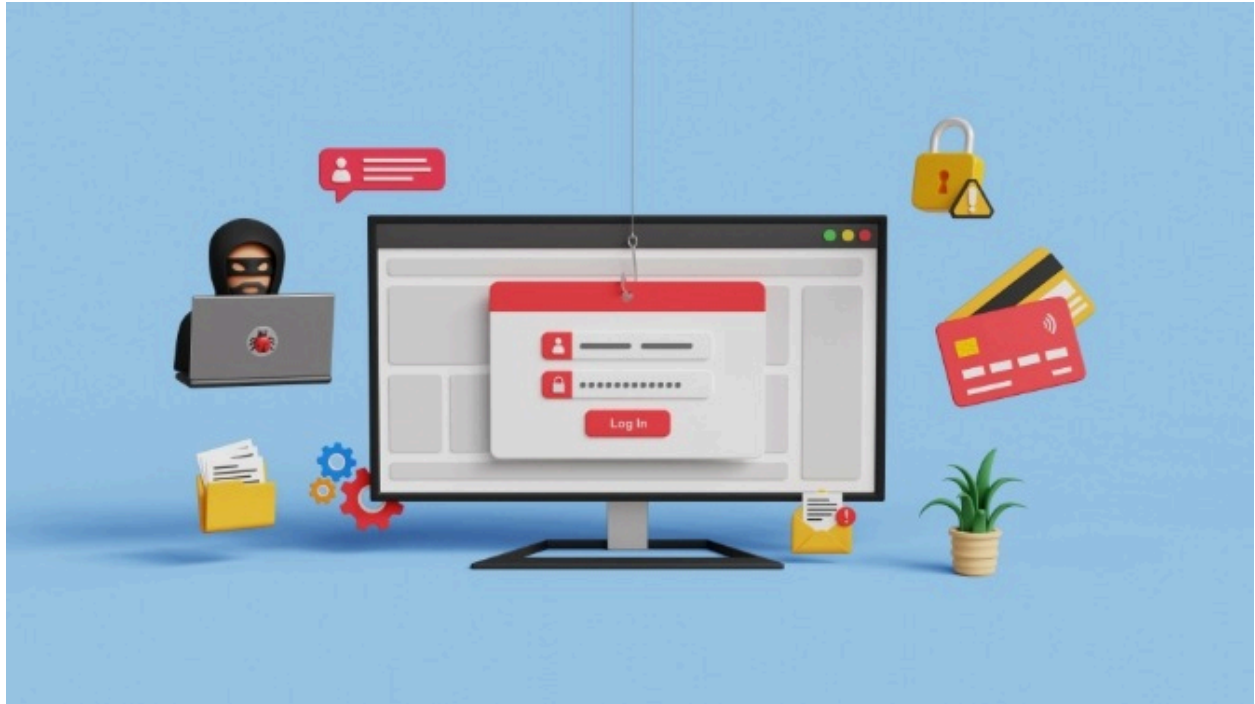


Reporte práctico

Actividad 04: Una página demasiado convincente



Guerrero Hurtado Lizbeth

Universidad Politécnica de San Luis Potosí
Ingeniería en Tecnologías de la Información | CNO IV - Seguridad Informática

Objetivo de la actividad

Objetivo General

Implementar y analizar, en un entorno de laboratorio controlado, una simulación de ingeniería social mediante Social-Engineer Toolkit (SET), utilizando una página web ficticia para comprender el funcionamiento de una técnica de captura de información y reconocer los elementos técnicos y visuales que permiten identificar un intento de phishing.

Objetivos Específicos

- Configurar un escenario básico de ingeniería social utilizando Social-Engineer Toolkit (SET) sobre Kali Linux.
- Implementar una página web ficticia institucional mediante el módulo Credential Harvester Attack Method.
- Analizar el proceso mediante el cual la información introducida en un formulario web de autenticación es transmitida HTTP, interceptada y registrada por el servidor atacante.
- Identificar al menos cinco (5) indicadores técnicos y visuales que permitan a un usuario o analista reconocer una página potencialmente fraudulenta.
- Proponer al menos cinco (5) controles de seguridad organizacionales y técnicos orientados a prevenir o reducir el impacto de ataques de phishing.

Descripción del Escenario

El área de seguridad informática de una organización ha recibido varios reportes de empleados que aseguran haber recibido un correo electrónico relacionado con una supuesta actualización urgente de sus credenciales de acceso institucional. El mensaje contiene un enlace que redirige a un portal aparentemente auténtico del sistema interno. La página incluye un logotipo institucional, campos de usuario y contraseña, y el mensaje de “Su sesión ha expirado. Inicie sesión nuevamente para continuar.”

A primera vista, nada parece fuera de lo común, sin embargo, el portal no pertenece a la organización y está alojado en una infraestructura controlada por un atacante simulado para la captura no autorizada de credenciales.

Configuración del laboratorio

Componentes	Rol dentro de la simulación	Especificaciones
Máquina atacante	Servicio SET	Kali Linux
Máquina víctima	Navegador del cliente simulado	Windows
Herramienta principal	Framework de Ingeniería social	Social Engineer Toolkit (SET)
Portal ficticio	Interfaz de autenticación institucional	Servidor web en puerto 80

Evidencia y descripción del funcionamiento

Iniciación de SET en Kali Linux

Se inicia la consola de comando de Kali Linux con privilegios elevados de superusuario (root) e invocamos el kit de herramientas de ingeniería social ejecutando el comando “**setoolkit**”.

Selección del Módulo

Dentro del menú interactivo de SET, se navega seleccionando las siguientes opciones en secuencia:

- 1) Social-Engineering Attacks
- 2) Website Attack Vectors
- 3) Credential Harvester Attack Method
- 4) Site Cloner -> Web Templates

Configuración de la dirección IP y Despliegue del servidor Web

El sistema solicita ingresar la dirección IP donde escuchará el servidor de captura (IP del servidor de Kali Linux) y la URL del sitio objetivo a clonar.

Simulación del Acceso del usuario e introducción de credenciales

En el equipo cliente o víctima, se abre el navegador web e ingresa la dirección del servidor

(<http://192.168.1.590>). Se despliega el formulario institucional fraudulento y el usuario podrá ingresar credenciales de prueba para la simulación.

Captura y registro de credenciales en consola

Al hacer clic en “Iniciar sesión”, los datos se enviarán mediante una petición HTTP POST al servidor SET, SET intercepta la petición, extrae los parámetros en claro (Username / Password) y los imprime en consola en tiempo real, guardándolos simultáneamente en un archivo de registros (log).

Justificación técnica, uso del modo consola (CLI) en Kali Linux.

Para la realización de esta práctica, la máquina virtual con Kali Linux fue configurada y ejecutada exclusivamente en Modo Consola (Interfaz de Línea de Comandos - CLI), prescindiendo del entorno gráfico de usuario (GUI). Esta decisión responde a los siguientes factores técnicos y de rendimiento:

- **Optimización de Recursos Hardware:** La máquina virtual contaba con una asignación restringida de memoria RAM (960 MB). Desactivar el servidor gráfico (X11/Wayland) y los entornos de escritorio como XFCE liberó aproximadamente entre 400 MB y 600 MB de memoria RAM, además de reducir sustancialmente el uso de ciclos de procesamiento de la CPU anfitriona.
- **Eficiencia Operativa en Servicios de Red:** Las herramientas avanzadas de ingeniería social y auditoría de seguridad, como Social-Engineer Toolkit (SET), servidores web (Apache/Python HTTP) y utilidades de transferencia (wget, curl), operan nativamente mediante comandos de terminal. El uso directo de la línea de comandos elimina capas de abstracción innecesarias y acelera la ejecución de los módulos de ataque y captura de credenciales.
- **Estabilidad del Entorno de Prueba:** Al minimizar la carga del sistema operativo huésped, se previenen bloqueos, ralentizaciones o fallos por falta de memoria (Out-Of-Memory/OOM Kills) durante la inicialización del servidor de escucha de SET en el puerto 80 HTTP.

Explicación del flujo de capturas de información

El proceso mediante el cual SET logra interceptar las credenciales se divide en cuatro fases

principales de comunicación:

- 1) **Despliegue del escucha HTTP:** SET inicializa un servidor web en el puerto 80 de la máquina atacante, modifica la etiqueta <from action= “...”> del código html clonado para que apunte directamente a la dirección IP del atacante.

```
(kali㉿ kali)-[~]
$ mkdir -p ~/phishing_lab && cd ~/phishing_lab

(kali㉿ kali)-[~/phishing_lab]
$ wget http://192.168.56.1:8000/index.html
--2026-08-31 03:12:48-- http://192.168.56.1:8000/index.html
Connecting to 192.168.56.1:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 9059 (8.8k) [text/html]
Saving to: 'index.html'

index.html                               100%[=====] 8.85K --.-KB/s in 0.02s

2026-08-31 03:12:49 (380 KB/s) - 'index.html' saved [9059/9059]

(kali㉿ kali)-[~/phishing_lab]
$ ls -la
total 20
drwxrwxr-x 2 kali kali 4096 Aug 31 03:12 .
drwx----- 6 kali kali 4096 Aug 31 03:12 ..
-rw-rw-r-- 1 kali kali 9059 Aug 31 02:53 index.html

(kali㉿ kali)-[~/phishing_lab]
$ _
```

- 2) **Navegación y solicitud GET:** La víctima accede a la dirección IP o al dominio malicioso, el servidor responde enviando el archivo html/css de la página simulada. Debido a la ausencia de HTTPS todo el tráfico entre cliente y servidor viaja sin algún cifrado.

```
1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

set:webattack>3
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report
-----
--- * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * ---

The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

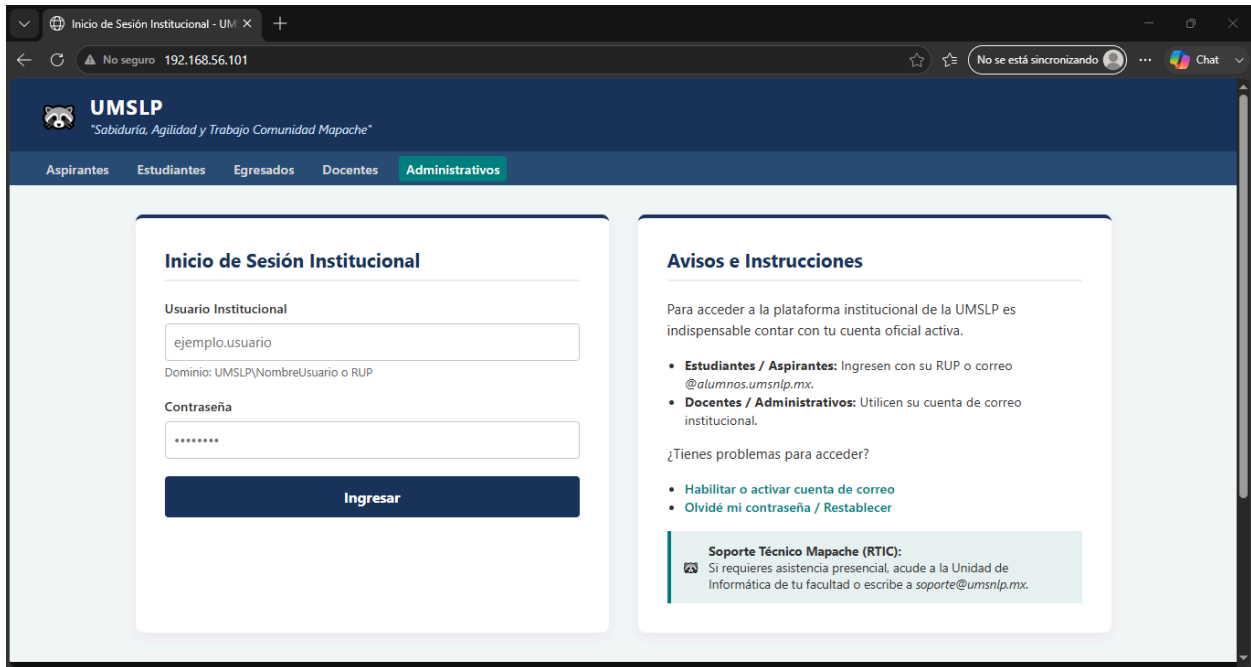
Enter the IP address for POST back in Harvester/Tabnabbing: 192.168.56.101
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/phishing_lab
[*] Index.html found. Do you want to copy the entire folder or just index.html?

1. Copy just the index.html
2. Copy the entire folder

Enter choice [1/2]: 1
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported:
```

- 3) **Envío de petición HTTP POST:** Cuando la víctima ingresa su usuario y contraseña y

presiona el botón de enviar, el navegador emite un paquete con el método POST.



- 4) **Parseo y redirección:** SET analiza (parsea) las variables del cuerpo de POST, las imprime en la consola del operador y las almacena en /root/.set/reports/. para evitar sospechas de la víctima. SET reorienta inmediatamente al usuario mediante una respuesta HTTP 302 redirección hacia la página legítima de la organización.

```
The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.56.1 - - [31/Aug/2026 03:19:01] "GET / HTTP/1.1" 200 -
192.168.56.1 - - [31/Aug/2026 03:19:15] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=mapache.prueba
POSSIBLE PASSWORD FIELD FOUND: password=mapaches123
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

Indicadores de Phishing y controles de seguridad propuestos

Indicadores de Phishing

- 1) **Inexistencia de HTTPS/ Certificación SSL:** El uso del protocolo http:// es inseguro sin candado de seguridad o presencia de advertencias de certificados autofirmados / no válidos.
- 2) **Dominio / Dirección sospechosa:** La URL en la barra de direcciones utiliza una

dirección IP directa (<http://192.168.56.101>) o un dominio typo-squatted que difiere del dominio oficial institucional.

- 3) **Urgencia y Coacción psicológica:** Se reciben mensajes alarmistas como “Su sesión ha expirado” o “Su cuenta será suspendida en 24 horas” diseñados para anular el juicio crítico del usuario.
- 4) **Enlaces e Incoherencias de los formularios:** El atributo action del formulario apunta a una dirección IP o servidor externo no relacionado con la infraestructura oficial.
- 5) **Anomalías estéticas y de tipografía:** Errores menores en logotipos desproporcionados, enlaces rotos o textos traducidos de manera automática que incluyen faltas de ortografía.

Controladores de seguridad propuestos

- 1) **Autenticación multifactor:** Implementación de tokens de seguridad para hardware (FIDO2/WebAuthn) o contraseñas de un solo uso (TOTP). Aunque se capture la contraseña el atacante no puede acceder sin el segundo factor dinámico.
- 2) **Implementación de DMARC, SPF y DKIM:** Configurar políticas estrictas de validación de correo para evitar el suplantamiento de identidad (spoofing) de dominios institucionales en mensajes de correo entrantes.
- 3) **Programa de concientización continua:** Capacitaciones periódicas y campañas de simulación de phishing para enseñar tanto a personal administrativo, docente y alumnado a verificar la URL y reportar correos sospechosos al equipo SOC/CSRT).
- 4) **Filtros antiphishing y DNS filter:** Desplegar resolvers DNS con filtrado de reputación (Cisco Umbrella, Cloudflare Teams) que bloquean dominios recién registrados o accesos por IP directa no autorizados.
- 5) **Generadores de contraseñas corporativas:** Uso de gestores que auto-completen credenciales únicamente si el dominio exacto en la barra del navegador coincide con el registro guardado, bloqueando así la inserción automática en sitios clonados.

CONCLUSIÓN

La realización de esta práctica demostró la facilidad con la que los atacantes pueden replicar interfaces legítimas utilizando herramientas automatizadas como Social Engineer Toolkit (SET). A través de la simulación del módulo de Credential Harvester, fue posible observar cómo la falta de validación del dominio por parte del usuario y la transmisión de la información en canales no cifrados (HTTP) exponen de forma crítica las credenciales corporativas.

La seguridad informática no depende exclusivamente de parches tecnológicos, sino de un enfoque en defensa en profundidad donde la concienciación del factor humano interactúa de manera complementaria con controles técnicos robustos como MFA y filtrado de reputación web.

REFERENCIAS

- **CISA. (2023).** *Phishing Guidance: Stopping the Attack Before It Starts*. Cybersecurity and Infrastructure Security Agency.
<https://www.cisa.gov/resources-tools/resources/phishing-guidance-stopping-attack-it-starts>
- **FIDO Alliance. (2022).** *How FIDO Works: User Authentication with Passkeys and Security Keys*. FIDO Alliance. <https://fidoalliance.org/how-fido-works/>
- **Mozilla Developer Network (MDN). (2023).** *HTTP POST method*. MDN Web Docs. <https://developer.mozilla.org/en-US/docs/Web/HTTP/Methods/POST>
- **OWASP Foundation. (2021).** *OWASP Top Ten 2021: A02:2021 – Cryptographic Failures*. OWASP. https://owasp.org/Top10/A02_2021-Cryptographic_Failures/
- **TrustedSec. (s.f.).** *The Social-Engineer Toolkit (SET) Manual*. TrustedSec. <https://www.trustedsec.com/tools/the-social-engineer-toolkit-set>